Microsoft Purview FedRAMP Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview FedRAMP Compliance Program 5

The problem . . . 5

The solution . . . 5

What you get . . . 5

Approach . . . 5

Boundaries . . . 5

The bottom line . . . 6

1. Solution Overview — Microsoft Purview FedRAMP Compliance Program 6

What this solution is . . . 6

Why this matters . . . 6

How it works . . . 7

The control stack this solution configures . . . 7

What you can control . . . 8

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 9

2. Requirements Guide — Microsoft Purview FedRAMP Compliance Program 9

2.1 Compliance licensing for information protection, DLP, and audit evidence . . . 9

2.2 Least-privilege roles for labels, DLP, audit, and Compliance Manager . . . 10

2.3 Security & Compliance PowerShell + Graph toolchain . . . 10

2.4 In-scope controlled data, workloads, and classification intent . . . 10

2.5 The NIST-800-53-to-control map and control baseline (from security/compliance) . . . 11

2.6 DLP simulation/test preconditions and endpoint onboarding . . . 11

2.7 Unified audit logging on, and an evidence-retention requirement (NIST AU) . . . 11

2.8 A pilot scope, simulation/test mode, and change control . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — Microsoft Purview FedRAMP Compliance Program 14

Step 1 — Assess current controls and licensing (Assess) . . . 14

Step 2 — Design the NIST-800-53-to-control map (Design) . . . 15

Step 3 — Configure the information-protection control (Configure → Pilot) . . . 15
Step 4 — Configure the DLP control — IN TEST / SIMULATION MODE (Configure → Pilot) . . . 15
Step 5 — Configure the audit-evidence and retention controls (Configure) . . . 16
Step 6 — Track the program in Compliance Manager (Configure, in-portal) . . . 16
Step 7 — Validate the controls and generate evidence (Validate) . . . 17
Step 8 — Expand to enforcement and operationalize (Expand) . . . 17
5. Testing & Validation — Microsoft Purview FedRAMP Compliance Program 17
Gate 1 — Compliance licensing present for each control . . . 17
Gate 2 — Sensitivity label applies (pilot, benign content) . . . 18
Gate 3 — DLP policy present IN TEST / SIMULATION mode . . . 18
Gate 4 — DLP matches and reports on benign test content (no blocking) . . . 18
Gate 5 — Unified audit on and evidence policy present (AU) . . . 18
Gate 6 — Controlled-records retention scoped . . . 18
Gate 7 — Compliance Manager assessment reflects the controls . . . 19
Gate 8 — Control map and evidence binder generated . . . 19
Gate 9 — Validation scorecard is green (pilot) . . . 19
Evidence to retain . . . 19
6. Troubleshooting — Microsoft Purview FedRAMP Compliance Program 20
A capability is missing from the portal or a cmdlet errors "not recognized" . . . 20
`Connect-IPPSSession` fails or hangs . . . 20
`Get-Label` / label cmdlets not found, or the label won't appear for users . . . 20
The DLP policy isn't blocking anything . . . 20
The DLP policy is unexpectedly ENFORCING (Enable) before sign-off . . . 20
DLP matches nothing on test content . . . 21
Endpoint DLP conditions do nothing . . . 21
Applying the encryption label broke access / downstream automation . . . 21
`Get-AdminAuditLogConfig` fails or ingestion shows False . . . 21
The audit / retention policy errored on `RetentionDuration` . . . 21
Two audit retention policies conflict / priority error . . . 21
Compliance Manager has no FedRAMP template . . . 22
The evidence binder shows a gap (a control with no object) . . . 22
Validation was green, now a gate is red (drift) . . . 22
7. Best Practices — A Defensible FedRAMP Program on Microsoft Purview 22
Stay in your lane: configure the control, defer the determination . . . 22
Treat DLP enforcement as a one-way risk — simulate first . . . 23
Encryption changes access — pilot it deliberately . . . 23

Make evidence a first-class deliverable . . . 23
Audit is the AU evidence layer — keep it on and retained . . . 23
Track it in Compliance Manager against the FedRAMP template . . . 23
Least-privilege everywhere, reviewed periodically . . . 24
Pilot every change, keep a rollback . . . 24
Operate it as a program, not a project . . . 24
8. Deliverables Summary — Microsoft Purview FedRAMP Compliance Program 24
Documentation . . . 24
PowerShell tools (5) . . . 25
Named artifacts created . . . 26
Definition of done . . . 26
Appendix A — PowerShell Scripts 28

Executive Summary — Microsoft Purview FedRAMP Compliance Program

The problem

For an organization pursuing or maintaining a FedRAMP authorization, an assessment comes down to two demands: *"show me the control"* and *"show me the evidence."* FedRAMP is built on the **NIST SP 800-53** control baselines, and its data-protection expectations — protecting controlled information, preventing unauthorized data loss, and preserving a defensible audit trail — too often exist as policy on paper with no mapped technical control behind them and no evidence that can be produced on demand. Left unaddressed, that is both a compliance gap and a data-risk exposure, and it surfaces at the worst possible moment: mid-assessment.

The solution

A complete, self-guided FedRAMP **control-and-evidence program** built on **Microsoft Purview**. It maps the in-scope NIST 800-53 controls to three configured Purview controls — **information protection** (sensitivity labels/encryption for controlled data), **DLP** (preventing unauthorized data loss), and **Audit & retention** (the evidence trail) — **pilots them in simulation/test/disabled mode**, validates them, and produces an **evidence binder** (control → configuration → proof) you can hand to an assessor. Five safe-by-default PowerShell tools (read-only or `-WhatIf` until you commit) do the assessment, scoping, configuration, validation, and evidence reporting.

What you get

- **A NIST-800-53-to-control register** — every in-scope control mapped to the Purview object that implements it, with the required scope and a named approver.
- **Information protection** — a controlled-data sensitivity label (with encryption where designed) piloted on benign content and published under sign-off.
- **DLP, simulated first** — a DLP policy built and validated **in test/simulation mode** (no blocking), moved to enforcement only after the pilot passes and security/compliance sign off.
- **An audit-evidence trail (AU)** — unified audit on, with a long-term retention policy keeping the evidence your compliance function requires, plus controlled-records retention.
- **An assessor-ready evidence binder** — control → configuration → proof, regenerated on a cadence so it is always current.

Approach

Delivery follows a disciplined, reversible model — **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)** — piloting every high-impact control on a limited scope before enforcement, with pass/fail gates and documented rollback. The consequential steps — **DLP enforcement** and **encryption application** — are gated behind explicit security/compliance sign-off.

Boundaries

Microsoft Purview is **licensing-/plan-dependent** (sensitivity-label encryption, DLP, and Audit Premium require E5 or the E5 Compliance add-on) and the portal is **actively evolving** — capabilities and paths are cited or flagged **"verify your licensing/tenant,"** never assumed. Above all: **the applicable FedRAMP baseline (Low/Moderate/High), which NIST 800-53 controls are in scope, whether a Purview object satisfies a control, and any ATO/authorization decision are deferred to your security, compliance, and legal functions** — this solution provides the technical control and the evidence, **not** the determination and **not** any certification or ATO claim.

The bottom line

A FedRAMP program that is **configured, piloted, validated, and evidenced** in Microsoft Purview — so when an assessor asks to see the control and the proof, both are already in hand.

1. Solution Overview — Microsoft Purview FedRAMP Compliance Program

What this solution is

An organization pursuing (or maintaining) a FedRAMP authorization lives and dies by two questions from an assessor: *"Show me the control"* and *"Show me the evidence."* FedRAMP is built on the **NIST SP 800-53** control baselines, and its data-protection expectations — protecting controlled information, preventing unauthorized data loss, and preserving a demonstrable audit trail — need to be **mapped to concrete controls**, those controls **configured**, and the whole thing **evidenced** in a form you can hand to an assessor without a scramble. This solution builds that program on **Microsoft Purview**: it maps the technical control surface (information protection, data-loss prevention, retention and audit evidence) to a FedRAMP-aligned control register, **configures** the controls in Purview — sensitivity labels/encryption, DLP, and audit/retention evidence — **pilots them in simulation/test/disabled mode first**, validates, and produces an **evidence binder** you can defend. It uses only the **Microsoft Purview portal** (`purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling.

> ***This is a technical-control-and-evidence program, not an authorization.*** *Whether your tenant meets FedRAMP, which **baseline** applies (Low / Moderate / High), which NIST 800-53 control an object satisfies, and whether any configuration supports an **Authorization to Operate (ATO)** are **compliance, security, and legal determinations** deferred to your **security, compliance, and authorizing functions**. This solution provides the Purview method, the configured control, and the evidence — **not** the determination and **not** any certification or ATO claim.*

Why this matters

- **FedRAMP is control-mapping plus evidence.** FedRAMP inherits the **NIST SP 800-53** control families — Access Control (**AC**), Audit & Accountability (**AU**), System & Communications Protection (**SC**), Media Protection (**MP**), Identification & Authentication (**IA**), Configuration Management (**CM**) — and an assessor expects each in-scope control to have an implementing mechanism and evidence. Purview provides implementing mechanisms for the data-centric families and, via **Compliance Manager**, a place to track them.

• **DLP is a high-impact control — pilot it in simulation first.** Data-loss prevention aligned to SC/AC can block real user actions if enforced blind. Purview DLP supports a **test / simulation** mode; this solution **always** creates and pilots DLP in test mode first, and enforces only after validation and sign-off.

• **Evidence is the deliverable assessors actually want.** A control that works but can't be *shown* to work fails an assessment. This solution's reporting produces a **control-to-configuration-to-evidence** binder so "the control is in place" is provable, not asserted.

• **The controls are licensing-dependent and evolving.** Sensitivity labels with encryption, DLP, auto-classification, and Audit Premium require **Microsoft 365 E5** or the **E5 Compliance** add-on; the portal and assessment templates change. Capabilities are **cited or flagged "verify your licensing/tenant"**, never assumed.

How it works

1. **Assess.** Discover what you already have — compliance licensing/plans, the least-privilege roles, existing sensitivity labels and label policies, DLP policies (and their mode), retention labels/policies, unified-audit state, and audit retention — so the program is built on facts, not assumptions.

2. **Design the control map.** With security/compliance, map the in-scope FedRAMP (NIST 800-53) controls to the three Purview control domains (information protection, DLP, retention & audit evidence) and to the **named artifacts** below. The control-to-object mapping is the security/compliance function's determination; this solution provides the register structure and the technical control.

3. **Configure — in simulation/test first.** Create the sensitivity label (with encryption where designed), the DLP policy **in test/simulation mode**, and the audit-evidence and retention policies. Every high-impact change is piloted disabled/simulated before enforcement.

4. **Pilot & validate.** Prove the label applies and protects, the DLP policy matches and reports (in test mode, no blocking) against benign test content, and audit evidence is retained — on a bounded **pilot scope** before tenant-wide enforcement.

5. **Produce the evidence.** Generate the control-mapping + evidence binder (control → Purview object → configuration → proof) for the security/compliance package.

6. **Expand & operate.** Move DLP from test to enforce and expand label/retention scope on the approved scope, schedule the read-only re-assessment so drift is caught, and hand the binder and runbook to the security/compliance function as a standing procedure.

The control stack this solution configures

• **Information protection** — sensitivity **labels** (with **encryption**/rights protection where designed) and **label policies** across Exchange, SharePoint, OneDrive, and Teams — the controlled-data protection mechanism supporting NIST **AC** (access control), **MP** (media protection), and **SC** (protection at rest/in transit).

• **Data Loss Prevention (DLP)** — **DLP policies and rules** that detect and (once enforced) restrict egress of controlled data across the same workloads and endpoints — the unauthorized-data-flow mechanism supporting NIST **SC**/**AC**. *High-impact — always piloted in test/simulation mode first.*

• **Audit (Standard/Premium) & Retention** — unified audit logging and **audit log retention policies** (the **AU** evidence trail), plus retention **labels/policies** preserving controlled records.

• **Compliance Manager** — the FedRAMP **assessment template** (e.g. **FedRAMP Moderate / FedRAMP High**, subject to your licensing) that tracks improvement actions and scores control implementation — the control-tracking layer (configured in-portal; determination of baseline/applicability is security/compliance's).

What you can control

• Which **sensitivity label(s)** protect controlled data, whether they apply **encryption**/rights protection, and their **label policy** scope.

• The **DLP** policy scope, conditions (which sensitive info types / labels), and actions — built and piloted in **test/simulation mode** first.

• Which record types/operations/users get **extended audit retention** as evidence, and which controlled records get retention.

• The **control register** (which NIST 800-53 control maps to which Purview object) and the **evidence binder** contents.

• The **pilot scope** validated in simulation/test/disabled mode before any enforcement.

Limitations (be honest with buyers)

• **We configure the control; we do not make the determination.** The applicable FedRAMP **baseline** (Low/Moderate/High), which NIST 800-53 controls are in scope, which controls a Purview object satisfies, and whether the tenant supports an **ATO** are **security/compliance/legal** determinations. **Verify with your security and authorizing functions.**

• **No certification or ATO claim.** This solution produces configured controls and evidence; it does **not** assert FedRAMP compliance, an ATO, or a 3PAO assessment outcome. Those are outside its scope.

• **DLP can disrupt users if enforced blind.** DLP is created and validated in **test/simulation mode** first; enforcement (blocking) is a separate, approved step after the pilot passes.

• **Encryption/labels are consequential.** Applying encryption to controlled data changes access — piloted on benign content first, with recovery/super-user and offboarding considerations understood before wider use.

• **Preservation and evidence are largely not retroactive.** Labels, retention, DLP telemetry, and audit evidence apply/accrue from configuration forward; they do not reach back to create history that wasn't captured — which is why configuring *now* matters.

Naming convention (used in every doc and script)

Every artifact this solution creates is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal. The standard set:

Artifact	Name
Controlled-data sensitivity label	`Protect – FedRAMP Controlled – Confidential`
Sensitivity-label publish policy	`Protect – FedRAMP Controlled – Publish`
DLP policy (test/simulation)	`DLP – FedRAMP Controlled – Simulate`
Controlled-records retention policy	`Retention – FedRAMP Records – Publish`
Audit evidence retention policy	`Audit Retention – FedRAMP Evidence – LongTerm`
Compliance Manager assessment	`Assessment – FedRAMP Controls – Program`
Control-mapping register	`Control Map – FedRAMP – Purview`
Evidence binder export	`Evidence – FedRAMP Controls – Binder`
Pilot validation scope	`FedRAMP Pilot – Controlled Data – Stage1`

The standard deployment model

> *Assess the controls and licensing you have → design the NIST-800-53-to-Purview control map with security/compliance → configure information protection, DLP, and audit/retention evidence →* ***pilot in simulation/test/disabled mode*** *on a limited scope → validate the controls work and produce evidence → expand to enforcement. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand (enforce).*** *High-impact controls (DLP, encryption labels, retention) are always piloted before enforcement.*

2. Requirements Guide — Microsoft Purview FedRAMP Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant/licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, compliance/security/legal stakeholders, pilot & change control) are in `global-requirements-purview.md` — this guide adds the FedRAMP-program detail.

> ***Determination/licensing boundary.*** *Sensitivity labels with encryption, DLP, auto-classification, and Audit Premium require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on and evolve; confirm your entitlements rather than assuming.* ***Which FedRAMP baseline applies (Low/Moderate/High), which NIST 800-53 controls are in scope, which control a Purview object satisfies, and whether the tenant supports an ATO*** *are* ***security/compliance/legal determinations*** *— this solution configures the control and produces evidence; it does not make the determination and asserts no certification/ATO. Where this guide flags "verify your licensing/tenant" or "security/compliance to determine," do so before relying on the item.*

2.1 Compliance licensing for information protection, DLP, and audit evidence

Description: The program spans three licensed control domains. **Sensitivity labels with encryption** and **auto-classification** need **E5 / E5 Compliance**; **DLP** (advanced conditions, endpoint DLP) needs **E5 / E5 Compliance**; **Audit Premium** (high-value events, long-term retention) needs **E5 / E5 Compliance / Audit add-on**, assigned **per user**. Compliance Manager's **FedRAMP assessment templates** (Moderate/High) may require premium templates. **Why:** Every control below is plan-gated; the feature won't be available without the right plan (GR §1). **Verify:** M365 admin center → `Billing → Licenses`; and run `CMPFEDRAMP-Discovery.ps1`, which reports whether information-protection / DLP / Audit-Premium-bearing plans are present via Graph. **Confirm plan/service-plan names against your tenant — they change. Implement:** Assign/purchase E5 or the relevant add-ons to in-scope users before expecting the feature.

2.2 Least-privilege roles for labels, DLP, audit, and Compliance Manager

Description: Distinct least-privilege roles for each domain — **Information Protection** (Admin / Analyst) for sensitivity labels & policies; **Compliance Administrator** / **DLP Compliance Management** for DLP; **Records/Retention Management** for retention; **Audit Manager/Reader** for evidence; **Compliance Manager** roles for the assessment. Global Administrator only where genuinely required. **Why:** Purview uses fine-grained role groups; configuration requires the matching role, and least-privilege is itself a control expectation (GR §2). **Verify:** Purview portal → `Settings → Roles & scopes / Permissions` — confirm membership per domain; `CMPFEDRAMP-Scope.ps1` reports the role groups it can see and connection identity. **Implement:** Assign the least-privilege role groups under change control; reserve Global Administrator for one-time enablement.

2.3 Security & Compliance PowerShell + Graph toolchain

Description: A workstation with the `ExchangeOnlineManagement` module (for `Connect-IPPSSession` — sensitivity labels (`*-Label`/`*-LabelPolicy`), DLP (`*-DlpCompliancePolicy`/`*-DlpComplianceRule`), retention (`*-RetentionCompliancePolicy`/`*-ComplianceTag`), and `*-UnifiedAuditLogRetentionPolicy`) and `Microsoft.Graph` (licensing reads), with a modern-auth/MFA admin. **Why:** All configuration and the provided scripts run through Security & Compliance PowerShell and Graph (GR §3). **Verify:** `Get-Module -ListAvailable ExchangeOnlineManagement`; `Connect-IPPSSession` and `Connect-MgGraph` succeed; `CMPFEDRAMP-Discovery.ps1` reports which endpoints are reachable. **Implement:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser`; `Install-Module Microsoft.Graph -Scope CurrentUser`.

2.4 In-scope controlled data, workloads, and classification intent

Description: The **controlled information** in scope (the data whose FedRAMP baseline drives the program), the **workloads** holding it (Exchange, SharePoint, OneDrive, Teams, and — for endpoint DLP — onboarded devices), and a **classification intent** (which sensitive info types / label defines "controlled") to drive labels and DLP. **Why:** Labels, DLP, and retention key off the in-scope controlled data, workloads, and the classification scheme (GR §4). **Verify:** Confirm the controlled-data definition, in-scope workloads/endpoints, and the classification approach with security/compliance; `CMPFEDRAMP-Scope.ps1` enumerates the target group's members and the mailboxes/sites in scope (read-only). **Implement:** Define the controlled-data scope and classification intent before authoring controls.

2.5 The NIST-800-53-to-control map and control baseline (from security/compliance)

Description: A documented statement — **from security and compliance** — of the applicable FedRAMP **baseline** (Low/Moderate/High), which **NIST SP 800-53 controls** (AC, AU, SC, MP, IA, CM, …) are in scope, which are addressed by Purview data-centric mechanisms, and who approves. **Why:** Baseline selection, control applicability, and whether a Purview object satisfies a control are **security/compliance determinations**, not technical defaults (GR §5); the solution configures to them and evidences them — it does not decide them. **Verify:** You can name, per in-scope control, the NIST 800-53 identifier, the implementing Purview object, and the named approver; these populate the `Control Map – FedRAMP – Purview` register. **Implement:** Capture the control map, baseline, and approvals before configuring — especially before applying **encryption** labels or **enforcing** DLP.

2.6 DLP simulation/test preconditions and endpoint onboarding

Description: For the DLP control specifically: agreement that DLP is built and validated in **test/simulation mode** first (no blocking), the **sensitive info types / label** that define a match, the intended **actions** at enforcement, and — if endpoint DLP is in scope — that devices are **onboarded** to Purview. **Why:** DLP can block real user actions; enforcing it blind is disruptive and risky (GR §6). Endpoint DLP requires device onboarding before any endpoint condition works. **Verify:** The match definition and intended actions are documented; `CMPFEDRAMP-Discovery.ps1` reports existing DLP policies and their **mode**; device onboarding status is confirmed in-portal if endpoint DLP is in scope. **Implement:** Document the match/actions; onboard devices if needed; **build the policy in test mode** until validation and sign-off are complete.

2.7 Unified audit logging on, and an evidence-retention requirement (NIST AU)

Description: `UnifiedAuditLogIngestionEnabled` must be **true** so the AU audit-trail control captures evidence, plus a documented statement of how long audit **evidence** must be retained for the baseline. **Why:** No audit evidence is written while ingestion is off, and it is **not retroactive**; retention duration is a compliance determination (GR §5/§6). **Verify:** `CMPFEDRAMP-Discovery.ps1` reports `UnifiedAuditLogIngestionEnabled` and existing audit retention policies. **Implement:** Enable unified audit under change control (via the Purview Audit solution / Exchange Online), then create the evidence-retention policy in the Implementation Guide.

2.8 A pilot scope, simulation/test mode, and change control

Description: A bounded **pilot scope** (`FedRAMP Pilot – Controlled Data – Stage1` — a small set of controlled-data owners/mailboxes/sites) and a **change-control** window. Sensitivity labels can be trialed on benign content; DLP supports **test/simulation** mode; audit/retention changes are reversible. **Why:** DLP, encryption labels, and retention are **high-impact** — so every change is piloted in simulation/test/disabled mode before enforcement (GR §6). **Verify:** A named pilot scope, confirmation that test/simulation/disabled mode is available for each control, and a change window/approval path. **Implement:** Define the pilot scope and agree change control before enabling, enforcing, or applying any control — **never enforce DLP or apply encryption outside the pilot without explicit sign-off.**

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview FedRAMP Compliance Program

Follow these steps **in order**. Configuration uses the **Microsoft Purview portal** (`https://purview.microsoft.com`), **Security & Compliance PowerShell** (`Connect-IPPSSession` — the `*-Label`/`*-LabelPolicy`, `*-DlpCompliancePolicy`/`*-DlpComplianceRule`, `*-RetentionCompliancePolicy`/`*-ComplianceTag`, and `*-UnifiedAuditLogRetentionPolicy` cmdlets), and **Microsoft Graph** (licensing). Every write is gated: scripts run **read-only or `-WhatIf` by default** and only change state with `-Commit`. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim.

> ***Model:** Assess the controls/licensing you have → design the NIST-800-53-to-Purview control map with security/compliance → configure information protection, DLP (in test/simulation), and audit/retention evidence → **pilot in simulation/test/disabled mode** → validate and evidence → expand to enforcement. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce). Determination boundary:** the FedRAMP baseline, which NIST 800-53 controls apply, whether a Purview object satisfies a control, and whether the tenant supports an ATO are **security/compliance/legal** determinations. This guide configures the control and evidences it; it does not make the determination and asserts no certification/ATO. **DLP is enforced only after the test/simulation pilot passes and sign-off is obtained.***

Step 1 — Assess current controls and licensing (Assess)

1. Run `CMPFEDRAMP-Discovery.ps1` (read-only). It connects to Security & Compliance PowerShell and Graph and reports:

• compliance licensing present (information-protection / DLP / Audit Premium-bearing plans — **verify plan names for your tenant**),

• existing **sensitivity labels** (`Get-Label`) and **label policies** (`Get-LabelPolicy`), flagging any that apply **encryption**,

• existing **DLP policies** (`Get-DlpCompliancePolicy`) and their **Mode** (flagging any already in **Enable**/enforce),

• existing **retention labels/policies** (`Get-ComplianceTag` / `Get-RetentionCompliancePolicy`),

• `UnifiedAuditLogIngestionEnabled` and existing **audit retention policies** (`Get-UnifiedAuditLogRetentionPolicy`).

1. Run `CMPFEDRAMP-Scope.ps1` (read-only) to enumerate the intended controlled-data owners group, in-scope mailboxes/sites, and the role groups it can see (Requirement 2.2/2.4).

2. Record the gaps against the three control domains. **Pass gate:** a written current-state for information protection, DLP, and audit/retention.

Step 2 — Design the NIST-800-53-to-control map (Design)

1. With security/compliance (Requirement 2.5), populate the `Control Map – FedRAMP – Purview` register: for each in-scope NIST 800-53 control, name the Purview control object that implements it, the required scope, and the approver. **The control-to-object mapping is security/compliance's determination; you provide the register and the technical control.**

2. Map the control families to the standard named artifacts:

• Information protection (**AC / MP / SC**) → `Protect – FedRAMP Controlled – Confidential` (label) + `Protect – FedRAMP Controlled – Publish` (label policy).

• Data-loss prevention (**SC / AC**) → `DLP – FedRAMP Controlled – Simulate` (built in test/simulation mode).

• Audit evidence (**AU**) → `Audit Retention – FedRAMP Evidence – LongTerm`; controlled-records retention → `Retention – FedRAMP Records – Publish`.

• Control tracking → `Assessment – FedRAMP Controls – Program` (Compliance Manager).

1. Define the pilot scope `FedRAMP Pilot – Controlled Data – Stage1` (Requirement 2.8). **Pass gate:** the control map, baseline, pilot, and approvals are documented.

Step 3 — Configure the information-protection control (Configure → Pilot)

1. Create the sensitivity label with the helper, `-WhatIf` first (prints the exact `New-Label` it would run). Pilot on benign content before applying encryption tenant-wide:

• `CMPFEDRAMP-Configure.ps1 -Control Label -WhatIf` → review → `-Commit` (creates `Protect – FedRAMP Controlled – Confidential`; add **encryption**/rights protection per the design — encryption changes access, so pilot on benign content first).

1. Publish the label to the pilot scope with a label policy:

• `CMPFEDRAMP-Configure.ps1 -Control Label -Publish -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -WhatIf` → review → `-Commit` (creates `Protect – FedRAMP Controlled – Publish` scoped to the pilot).

1. **Pass gate:** `CMPFEDRAMP-Discovery.ps1` lists the label and its publish policy scoped to the pilot; the label applies to benign pilot content (Testing Gate 2). **Rollback:** the label policy and label are removable (`-Control Label -Remove -Commit`) before wider adoption; once encryption-protected content exists, plan removal carefully (access/recovery implications — verify in your tenant).

Step 4 — Configure the DLP control — IN TEST / SIMULATION MODE (Configure → Pilot)

1. **Build the DLP policy in test/simulation mode** (no blocking) with the conditions your security/compliance function specified (the sensitive info types / the `Protect – FedRAMP Controlled – Confidential` label as the match). The helper defaults to `-WhatIf` and creates the policy in **test mode**:

• `CMPFEDRAMP-Configure.ps1 -Control DLP -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -WhatIf` → review → `-Commit` (creates `DLP – FedRAMP Controlled – Simulate` via `New-DlpCompliancePolicy -Mode TestWithoutNotifications` plus a `New-DlpComplianceRule` matching the controlled-data condition — **created in simulation/test mode; it does NOT block**).

1. Confirm the policy **matches and reports** against **benign test content** for the pilot scope without blocking any action, and review the DLP simulation/overview results in-portal. **Do not enforce (switch to `Enable`) until the pilot passes and sign-off is obtained.**

2. **Pass gate:** the DLP policy exists in **test/simulation** mode, is pilot-scoped, and reports matches on test content with no enforcement. **Rollback:** disable/remove the test policy (`-Control DLP -Remove -Commit`); in test mode no user action is ever blocked, so there is nothing to reverse for end users.

Step 5 — Configure the audit-evidence and retention controls (Configure)

1. Confirm unified audit is on (Requirement 2.7). Create the evidence-retention policy pilot-first:

• `CMPFEDRAMP-Configure.ps1 -Control Audit -PolicyName "Audit Retention – FedRAMP Evidence – LongTerm" -WhatIf` → review → `-Commit` (creates a `New-UnifiedAuditLogRetentionPolicy` for the record types/operations your compliance function requires as **AU** evidence, at the agreed duration and a unique priority). **Verify accepted `RetentionDuration` values and that the long-term tier is licensed** (Requirement 2.1).

1. Where the design calls for controlled-records preservation, create the retention policy:

• `CMPFEDRAMP-Configure.ps1 -Control Retention -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -WhatIf` → review → `-Commit` (creates `Retention – FedRAMP Records – Publish` scoped to the pilot locations).

1. **Pass gate:** `CMPFEDRAMP-Discovery.ps1` lists the audit retention policy (expected duration/priority) and the retention policy scoped to the pilot. **Rollback:** `-Control Audit -Remove -Commit` / `-Control Retention -Remove -Commit` (already-retained records age out under remaining rules).

Step 6 — Track the program in Compliance Manager (Configure, in-portal)

1. In the Purview portal → **Compliance Manager**, create/assign the assessment `Assessment – FedRAMP Controls – Program` from a **FedRAMP assessment template** (e.g. **FedRAMP Moderate** or **FedRAMP High** — **template availability depends on your licensing; verify in-portal**). Map its improvement actions to the Purview controls configured above.

2. Record, per improvement action, the implementing Purview object and its evidence location (this cross-links to the `Control Map – FedRAMP – Purview` register). **Pass gate:** the assessment reflects the configured controls with evidence links. *(Compliance Manager assessment content, baseline choice, and applicability are security/compliance's determination; no cmdlet invents this — it is authored in-portal.)*

Step 7 — Validate the controls and generate evidence (Validate)

1. Run `CMPFEDRAMP-Validate.ps1` (read-only) to score the program across gates: label present (and encryption state as designed), DLP present **in test/simulation** and pilot-scoped, audit ingestion on with the evidence policy in place, retention policy scoped, and the pilot scope covered.

2. Run `CMPFEDRAMP-Report.ps1` (read-only) to produce `Evidence – FedRAMP Controls – Binder` — a control → Purview object → configuration → proof export (CSV/JSON) for the security/compliance package, cross-referenced to `Control Map – FedRAMP – Purview`.

3. Complete the **Testing Guide** before expanding. **Pass gate:** the validation scorecard is green for the pilot scope and the evidence binder is generated.

Step 8 — Expand to enforcement and operationalize (Expand)

1. Once the pilot passes and security/compliance signs off, expand scope: publish the label to the full controlled-data scope, extend the retention/audit-evidence policies, and **move the DLP policy from test/simulation to Enable (enforce)** on the approved scope — each under change control.

• `CMPFEDRAMP-Configure.ps1 -Control DLP -Enforce -WhatIf` → review → `-Commit` (switches `DLP – FedRAMP Controlled – Simulate` to `-Mode Enable`; consider renaming/annotating that it is now enforced). **Only after the pilot passes and sign-off is obtained.**

1. Schedule the read-only chain (`CMPFEDRAMP-Discovery.ps1` → `CMPFEDRAMP-Validate.ps1` → `CMPFEDRAMP-Report.ps1`) on a cadence so drift — a DLP policy silently disabled, a label unpublished, a lapsed license, audit turned off — is caught, and re-generate the evidence binder before each assessment cycle. **Pass gate:** controls enforced on the approved scope, evidence binder current, monitoring cadence scheduled. Hand the register, binder, and runbook to the security/compliance function as the standing procedure.

5. Testing & Validation — Microsoft Purview FedRAMP Compliance Program

Work through every gate. Each has a **method**, an **expected result (pass)**, and a **fail action**. Tests are read-only or use **benign, self-generated pilot content** — no production controlled data is exposed and **no DLP enforcement (blocking) is exercised during testing**. Do not declare "FedRAMP-ready" until every gate passes for the pilot scope, then re-confirm on expand.

> ***Boundary:*** *these gates prove the* ***technical control works and is evidenced****. Whether the control* ***satisfies*** *a specific NIST 800-53 control, which* ***baseline*** *applies, and whether the tenant supports an* ***ATO*** *are* ***security/compliance/legal determinations****, not test outcomes.* ***This solution asserts no certification or ATO.***

Gate 1 — Compliance licensing present for each control

• **Method:** `CMPFEDRAMP-Discovery.ps1` licensing section (Graph `subscribedSkus` / service plans).

• **Pass:** information-protection, DLP, and Audit Premium-bearing plans are present and assigned to the in-scope population.

• **Fail:** assign the license (Requirement 2.1); a missing plan makes the corresponding control unavailable — that is a licensing gap, not a config defect. **Verify plan names for your tenant.**

Gate 2 — Sensitivity label applies (pilot, benign content)

• **Method:** apply `Protect – FedRAMP Controlled – Confidential` to benign pilot content; confirm via `CMPFEDRAMP-Discovery.ps1` / portal that the label and its publish policy are scoped to the pilot.

• **Pass:** the label applies, and `Get-Label`/`Get-LabelPolicy` show it published to the pilot scope; if encryption is designed, protected content behaves as intended for a pilot user.

• **Fail:** confirm the label definition, the publish-policy scope, and label availability latency; retest. **Do not apply encryption tenant-wide until the pilot behavior is confirmed.**

Gate 3 — DLP policy present IN TEST / SIMULATION mode

• **Method:** `CMPFEDRAMP-Discovery.ps1` / `CMPFEDRAMP-Validate.ps1` — confirm `DLP – FedRAMP Controlled – Simulate` (`Get-DlpCompliancePolicy`) exists and its **Mode is a test/simulation mode** (not `Enable`), scoped to the pilot.

• **Pass:** the DLP policy exists, is pilot-scoped, and is in **test/simulation** mode (no blocking).

• **Fail:** correct the mode/scope with `CMPFEDRAMP-Configure.ps1 -Control DLP`; **never leave it in** `Enable` **before the pilot passes and sign-off is obtained.**

Gate 4 — DLP matches and reports on benign test content (no blocking)

• **Method:** generate **benign test content** matching the DLP condition (the controlled-data sensitive info type / label) for a pilot user; review the DLP **simulation/overview** results in-portal.

• **Pass:** the policy **reports** a match with **no user action blocked** (test mode); the match is visible in the DLP results.

• **Fail:** confirm the rule conditions/scope and ingestion latency; adjust and retest. **Match/condition adequacy for a control is security/compliance's determination, not a test.**

Gate 5 — Unified audit on and evidence policy present (AU)

• **Method:** `CMPFEDRAMP-Discovery.ps1` audit section (`UnifiedAuditLogIngestionEnabled`, `Get-UnifiedAuditLogRetentionPolicy`).

• **Pass:** ingestion is `True` and `Audit Retention – FedRAMP Evidence – LongTerm` exists with the agreed duration and a unique priority.

• **Fail:** enable ingestion under change control; create/correct the policy (Implementation Step 5); verify the `RetentionDuration` value and licensing.

Gate 6 — Controlled-records retention scoped

• **Method:** `CMPFEDRAMP-Discovery.ps1` / portal — confirm `Retention – FedRAMP Records – Publish` covers the in-scope locations for the pilot.

• **Pass:** the retention policy exists, is enabled, and covers the intended locations at the agreed duration.

• **Fail:** correct the locations/duration with `CMPFEDRAMP-Configure.ps1 -Control Retention`; re-verify. Confirm the retention duration with compliance (determination).

Gate 7 — Compliance Manager assessment reflects the controls

• **Method:** Purview portal → Compliance Manager — confirm `Assessment – FedRAMP Controls – Program` exists (from a FedRAMP template) and its improvement actions link to the configured Purview objects.

• **Pass:** the assessment is present and its actions cross-reference the `Control Map – FedRAMP – Purview` register with evidence links.

• **Fail:** create/assign the assessment (Implementation Step 6) and map actions to objects. Template availability/baseline is licensing- and compliance-dependent.

Gate 8 — Control map and evidence binder generated

• **Method:** `CMPFEDRAMP-Report.ps1` → `Evidence – FedRAMP Controls – Binder`, cross-referenced to `Control Map – FedRAMP – Purview`.

• **Pass:** every in-scope control maps to a Purview object with its configuration and a proof reference; the binder exports cleanly.

• **Fail:** fill the gap (missing control or missing evidence) and re-run. A control with no evidence fails an assessment.

Gate 9 — Validation scorecard is green (pilot)

• **Method:** `CMPFEDRAMP-Validate.ps1`.

• **Pass:** every gate above is green for the pilot scope (and, on expand, for the approved production scope with DLP enforced).

• **Fail:** address the specific red item and re-run before enforcing anything tenant-wide.

Evidence to retain

• `CMPFEDRAMP-Discovery.ps1` and `CMPFEDRAMP-Validate.ps1` outputs (before/after).

• The `-WhatIf` transcripts for every label, DLP, audit, and retention change.

• The `Evidence – FedRAMP Controls – Binder` export and the `Control Map – FedRAMP – Purview` register.

• The security/compliance sign-offs (DLP enforcement, encryption application, retention schedule, baseline) and the pilot roster/approvals (Requirement 2.5/2.6/2.8).

*Baseline selection, control applicability, NIST 800-53 sufficiency, and any ATO decision are **security/compliance/legal determinations** — these gates prove the Purview controls work and are*

evidenced, not that the program satisfies FedRAMP or supports an authorization.

6. Troubleshooting — Microsoft Purview FedRAMP Compliance Program

Symptom → likely cause → fix, for the failure modes this program actually hits. Diagnosis is read-only (`CMPFEDRAMP-Discovery.ps1` / `CMPFEDRAMP-Validate.ps1`); changes go through `CMPFEDRAMP-Configure.ps1` (`-WhatIf` first, `-Commit` to apply). Remember the boundary: these are **technical** fixes — baseline selection, NIST 800-53 applicability, and any ATO decision remain **security/compliance/legal's**, and this solution asserts **no certification or ATO**.

A capability is missing from the portal or a cmdlet errors "not recognized"

- **Cause:** licensing gap or a feature not enabled/available in your tenant. Sensitivity-label encryption, DLP, and Audit Premium require **E5 / E5 Compliance**; some features/cmdlets are region- or plan-gated and evolve.
- **Fix:** run `CMPFEDRAMP-Discovery.ps1` licensing section; confirm the plan is **present and assigned** to in-scope users (Requirement 2.1). **Verify plan/cmdlet names against your tenant and current Microsoft docs** — a missing plan is a licensing gap, not a config defect.

`Connect-IPPSSession` fails or hangs

- **Cause:** `ExchangeOnlineManagement` not installed, MFA/modern-auth prompt blocked, or a stale token.
- **Fix:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser`; run interactively so the MFA prompt appears; retry. `CMPFEDRAMP-Scope.ps1` reports endpoint reachability.

`Get-Label` / label cmdlets not found, or the label won't appear for users

- **Cause:** information-protection feature/licensing not available, or the label is created but **not published** to the pilot scope.
- **Fix:** verify licensing; create the label and its policy with `CMPFEDRAMP-Configure.ps1 -Control Label -Publish` and **scope the policy to the pilot users/locations** (not All). Allow for label-availability latency before it shows in apps.

The DLP policy isn't blocking anything

- **This is expected.** The policy is created in **test/simulation** mode (`TestWithoutNotifications` / `TestWithNotifications`) — it **matches and reports but does not block**. This is by design so you can tune before enforcing.
- **Fix (only after the pilot passes and sign-off):** `CMPFEDRAMP-Configure.ps1 -Control DLP -Enforce -Commit` switches it to `-Mode Enable`. Never enforce before the test pilot is validated.

The DLP policy is unexpectedly ENFORCING (Enable) before sign-off

• **Cause:** the policy was created/switched to `Enable` prematurely.

• **Fix:** `CMPFEDRAMP-Validate.ps1` flags this as a RED gate. Return it to test/simulation via the portal (or recreate with the helper) until the pilot passes and security/compliance sign off. Enforcing blind can block legitimate user actions.

DLP matches nothing on test content

• **Cause:** the rule conditions don't match your controlled-data definition (wrong sensitive info type / label), content-indexing latency, or the location isn't in scope.

• **Fix:** confirm the `New-DlpComplianceRule` conditions reflect the **controlled-data definition your security/compliance function specified** (match/lexicon adequacy is *their* determination, not a test); allow ingestion latency; verify the pilot location is in the policy scope. Review the DLP **simulation/overview** results in-portal.

Endpoint DLP conditions do nothing

• **Cause:** devices are **not onboarded** to Purview, so endpoint conditions can't evaluate.

• **Fix:** onboard the pilot devices to Purview (Requirement 2.6) before relying on any endpoint DLP condition; re-test on an onboarded device.

Applying the encryption label broke access / downstream automation

• **Cause:** a label with **encryption** changes who can open content and can affect guests, service accounts, and automation.

• **Fix:** this is why encryption is **piloted on benign content first**. Confirm recovery/super-user and offboarding behavior before wider use; if access broke, review the encryption/rights settings and the affected principals. Understand removal implications in **your** tenant before changing an in-use encryption label.

`Get-AdminAuditLogConfig` fails or ingestion shows False

• **Cause:** the cmdlet runs in **Exchange Online PowerShell** (`Connect-ExchangeOnline`), not only S&C PowerShell; or unified audit ingestion is genuinely off.

• **Fix:** `Connect-ExchangeOnline` and re-read; if `UnifiedAuditLogIngestionEnabled` is False, enable unified audit under change control (Requirement 2.7). Audit evidence is **not retroactive** — nothing is captured for the period it was off.

The audit / retention policy errored on `RetentionDuration`

• **Cause:** an unsupported duration value or an unlicensed long-term tier.

• **Fix: verify the accepted** `-RetentionDuration` **values and that the long-term tier is licensed** for your tenant (Requirement 2.1) before committing; adjust the `-Duration` / `-RetentionDuration` parameter and re-run `-WhatIf`.

Two audit retention policies conflict / priority error

• **Cause:** duplicate or overlapping `New-UnifiedAuditLogRetentionPolicy` priorities.

• **Fix:** give the evidence policy a **unique** `-Priority`; `CMPFEDRAMP-Discovery.ps1` lists existing policies and priorities so you can pick a free one.

Compliance Manager has no FedRAMP template

• **Cause:** the **FedRAMP Moderate / High** assessment templates may be premium and licensing-dependent, or not yet added.

• **Fix:** verify template availability in-portal against your licensing; add/assign the template and create `Assessment – FedRAMP Controls – Program` (Implementation Step 6). Baseline choice and applicability are **security/compliance's** determination.

The evidence binder shows a gap (a control with no object)

• **Cause:** the implementing Purview object doesn't exist (or is named differently from the register).

• **Fix:** `CMPFEDRAMP-Report.ps1` flags each gap. Configure the missing control (Implementation Guide) or align the name to `Control Map – FedRAMP – Purview`, then re-run. **A control with no evidence fails an assessment.**

Validation was green, now a gate is red (drift)

• **Cause:** a DLP policy disabled, a label unpublished, a lapsed license, or audit turned off since the last run.

• **Fix:** this is why the read-only chain (`CMPFEDRAMP-Discovery.ps1` → `CMPFEDRAMP-Validate.ps1` → `CMPFEDRAMP-Report.ps1`) is **scheduled**. Remediate the specific red item and regenerate the evidence binder before the next assessment cycle.

> *If a fix would require deciding the **baseline**, whether a Purview object **satisfies** a NIST 800-53 control, or anything touching an **ATO/authorization**, stop — those are **security/compliance/legal** determinations. This solution provides the technical control and the evidence, not the determination, and asserts no certification or ATO.*

7. Best Practices — A Defensible FedRAMP Program on Microsoft Purview

Operating principles for a control-and-evidence program that survives an assessment. Grounded in Microsoft's public guidance and the **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)** model.

Stay in your lane: configure the control, defer the determination

• **You implement and evidence controls; security/compliance decide the rules.** Which FedRAMP **baseline** applies (Low/Moderate/High), which **NIST 800-53** controls are in scope, whether a Purview object satisfies a control, and whether the tenant supports an **ATO** are **their** determinations. Capture them in the `Control Map – FedRAMP – Purview` register with named approvers — the register is

your defensibility.

• Write findings as "the control is configured as specified and evidenced," never "the tenant is FedRAMP-compliant / authorized." **This solution asserts no certification or ATO.**

Treat DLP enforcement as a one-way risk — simulate first

• Purview **DLP can block real user actions**. **Always build and validate DLP in test/simulation mode first** (`-Mode TestWithoutNotifications` / `TestWithNotifications`), confirm it matches the right controlled data with acceptable false positives, and switch to `Enable` **(enforce) only after the pilot passes and security/compliance sign off**.

• Review the DLP **simulation/overview** results before enforcing — tune conditions and exceptions in test so enforcement day is uneventful.

Encryption changes access — pilot it deliberately

• A sensitivity **label with encryption** changes who can open controlled content and can affect downstream automation, guest access, and offboarding. Pilot on **benign content** first, confirm recovery/super-user and offboarding behavior, and understand the removal implications **before** wider application.

• Keep the label taxonomy minimal and named — `Protect – FedRAMP Controlled – Confidential` — so its meaning is unambiguous in the control map.

Make evidence a first-class deliverable

• An assessor wants **control** → **configuration** → **proof**. Generate the `Evidence – FedRAMP Controls – Binder` regularly, not just at assessment time, so evidence is always current and gaps surface early.

• Retain the `-WhatIf` transcripts, before/after discovery outputs, and sign-offs — the *change history* of the control is itself evidence of a governed program.

Audit is the AU evidence layer — keep it on and retained

• Ensure **unified audit logging** stays on (it can be disabled) and that the `Audit Retention – FedRAMP Evidence – LongTerm` policy keeps the evidence your compliance function requires for the baseline, at a verified duration and licensing tier.

• Treat "is auditing on and retaining?" as a **standing monitored control**, caught by the scheduled read-only chain.

Track it in Compliance Manager against the FedRAMP template

• Use the **FedRAMP Moderate / High assessment template** in Compliance Manager as the single place improvement actions are tracked and scored, and cross-link each action to the implementing Purview object and its evidence. Baseline choice and template applicability are **security/compliance's** determination.

Least-privilege everywhere, reviewed periodically

• Information Protection, DLP Compliance Management, Records/Retention, Audit, and Compliance Manager roles are **distinct and least-privilege**; reserve Global Administrator for one-time enablement. Review membership periodically — least-privilege is itself a FedRAMP (AC) expectation.

Pilot every change, keep a rollback

• Enable, protect, and detect **pilot-first** in simulation/test/disabled mode; validate with the scorecard before expanding. Labels (pre-encryption), test-mode DLP, retention policies, and audit policies are reversible — record the exact rollback with every change. The consequential steps — **DLP enforcement** and **encryption application** — are gated behind explicit sign-off.

Operate it as a program, not a project

• Schedule `CMPFEDRAMP-Discovery.ps1` → `CMPFEDRAMP-Validate.ps1` → `CMPFEDRAMP-Report.ps1` on a cadence so drift (a DLP policy disabled, a label unpublished, a narrowed scope, a lapsed license, audit turned off) is caught before an assessor finds it, and re-generate the evidence binder ahead of every assessment cycle. Hand the register, binder, and runbook to security/compliance as the standing procedure.

8. Deliverables Summary — Microsoft Purview FedRAMP Compliance Program

What you receive, what to run, and what "done" looks like.

Documentation

Document	Purpose
1. Solution Overview	What the program is, the three Purview control domains (information protection, DLP, retention & audit evidence) mapped to NIST 800-53 families, what you control, honest limitations, and the naming convention.
2. Requirements Guide	FedRAMP-program prerequisites (licensing per control, least-privilege roles, S&C PowerShell + Graph toolchain, in-scope controlled data/workloads, the NIST-800-53-to-control map, DLP simulation preconditions, audit, pilot) — each with Verify / Implement.
3. Implementation Guide	Ordered steps: assess, design the control map, configure information protection / DLP (in test/simulation) / audit & retention, track in Compliance Manager, validate & evidence, expand to enforcement — pilot-in-simulation/test-first with pass/fail gates and rollback (and the DLP-enforcement sign-off gate).

Document	Purpose
5. Testing & Validation	Nine gates from "licensing present" to "validation scorecard green," each with method / pass / fail action — read-only or benign pilot content, no DLP enforcement exercised.
6. Troubleshooting	The failure modes — label/encryption behavior, DLP mode/scope, audit off, retention scope, licensing, endpoint confusion, evidence gaps — and their fixes.
7. Best Practices	Defensible-program principles: defer determinations, simulate DLP first, pilot encryption deliberately, make evidence first-class, operate it as a program.

PowerShell tools (5)

All run **read-only or `-WhatIf` by default**; writes require `-Commit`. No credentials or secrets are embedded. Sensitivity labels, DLP, retention, and audit retention cmdlets use **Security & Compliance PowerShell** (`Connect-IPPSSession`); licensing reads use **Microsoft Graph**.

Script	Role	Default			
`CMPFEDRAMP-Discovery.ps1`	Assess: licensing, sensitivity labels/policies (flag encryption), DLP policies (flag Mode), retention labels/policies, unified-audit state + audit retention.	Read-only			
`CMPFEDRAMP-Scope.ps1`	Scope/health helper: controlled-data-owners group members, in-scope mailboxes/sites, visible role groups, connection identity/health.	Read-only			

Script	Role	Default			
`CMPFEDRAMP-Configure.ps1`	Configure/Remediate: create the sensitivity label + publish policy, the DLP policy **in test/simulation**, audit-evidence and controlled-records retention — `-Control Label\	DLP\	Audit\	Retention`; -Enforce` switches DLP to Enable.	`-WhatIf` (writes on `-Commit`)
`CMPFEDRAMP-Validate.ps1`	Validate: program scorecard across label, DLP (present + in test/simulation), audit, retention, pilot coverage.	Read-only			
`CMPFEDRAMP-Report.ps1`	Report: control → object → configuration → proof export (`Evidence – FedRAMP Controls – Binder`), cross-referenced to the control map.	Read-only			

Named artifacts created

- Information protection: `Protect – FedRAMP Controlled – Confidential` (label), `Protect – FedRAMP Controlled – Publish` (label policy).
- DLP: `DLP – FedRAMP Controlled – Simulate` (built and validated in test/simulation mode; enforced only after sign-off).
- Audit evidence & retention: `Audit Retention – FedRAMP Evidence – LongTerm`, `Retention – FedRAMP Records – Publish`.
- Program tracking: `Assessment – FedRAMP Controls – Program` (Compliance Manager, in-portal).
- Governance/evidence: `Control Map – FedRAMP – Purview`, `Evidence – FedRAMP Controls – Binder`, pilot `FedRAMP Pilot – Controlled Data – Stage1`.

Definition of done

- Compliance **licensing confirmed** for information protection, DLP, and audit evidence on the in-scope population.

• Information-protection control in place — `Protect – FedRAMP Controlled – Confidential` label piloted on benign content and published to the approved scope (encryption applied per design under sign-off).

• DLP policy `DLP – FedRAMP Controlled – Simulate` present **in test/simulation** mode, pilot-scoped, reporting matches with no blocking — then moved to **Enable (enforce)** on the approved scope **under sign-off**.

• **Unified audit on** with `Audit Retention – FedRAMP Evidence – LongTerm` retaining AU evidence, and `Retention – FedRAMP Records – Publish` scoped where required.

• The `Control Map – FedRAMP – Purview` register complete and the `Evidence – FedRAMP Controls – Binder` generated; the **validation scorecard green** for the pilot — then expanded with a monitoring cadence and the Compliance Manager assessment tracking the program.

Boundary: *this solution delivers the technical control configuration and the evidence.* ***The applicable baseline, NIST 800-53 control applicability, whether a Purview object satisfies a control, and any ATO/authorization decision are deferred to your security, compliance, and legal functions — this solution asserts no certification or ATO.*** *Feature availability is* ***licensing-/tenant-dependent and evolving — verify against your entitlements and current Microsoft documentation.***

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CMPFEDRAMP-Configure.ps1

Purpose: Configures one FedRAMP control domain at a time (-Control Label|DLP|Audit|Retention) using Security & Compliance PowerShell. SAFE BY DEFAULT: prints the exact cmdlet it WOULD run and makes NO change unless -Commit is passed. DLP is ALWAYS created in TEST/simulation mode (no blocking); switching it to enforce (Enable) requires the explicit -Enforce switch AND sign-off. Sensitivity labels are created without encryption unless you add it per your design (encryption changes access — pilot on benign content first). No secrets in code. HOW TO RUN 1) Sensitivity label + publish policy — preview then commit: .\CMPFEDRAMP-Configure.ps1 -Control Label -WhatIf .\CMPFEDRAMP-Configure.ps1 -Control Label -Publish -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -Commit 2) DLP policy IN TEST/simulation (no blocking): .\CMPFEDRAMP-Configure.ps1 -Control DLP -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -WhatIf 2b) After the pilot passes AND sign-off — switch DLP to enforce: .\CMPFEDRAMP-Configure.ps1 -Control DLP -Enforce -WhatIf 3) Audit evidence retention: .\CMPFEDRAMP-Configure.ps1 -Control Audit -PolicyName "Audit Retention – FedRAMP Evidence – LongTerm" -RecordTypes AzureActiveDirectory -Duration TenYears -Priority 150 -WhatIf 4) Controlled-records retention: .\CMPFEDRAMP-Configure.ps1 -Control Retention -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -WhatIf Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin. EXPECTED RESULTS -WhatIf prints each intended create/remove/change with no change. -Commit performs it and re-reads the object. PASS = object exists as intended (DLP in TEST until -Enforce). Remove objects with -Remove. Switching DLP to Enable can block users — do it only under sign-off. .NOTES Purview category — FedRAMP Compliance Program. High-impact: DLP, encryption labels, and retention are piloted in simulation/test/disabled mode first. Baseline, NIST 800-53 applicability, DLP conditions, and retention durations are security/compliance/legal determinations — supplied by you, not invented here. No certification/ATO asserted. Verify cmdlet/plan availability for your tenant. > [CmdletBinding()] param([Parameter(Mandatory)][ValidateSet('Label','DLP','Audit','Retention')][string]$Control,

How to run: 1) Sensitivity label + publish policy — preview then commit: .\CMPFEDRAMP-Configure.ps1 -Control Label -WhatIf .\CMPFEDRAMP-Configure.ps1 -Control Label -Publish -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -Commit 2) DLP policy IN TEST/simulation (no blocking): .\CMPFEDRAMP-Configure.ps1 -Control DLP -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -WhatIf 2b) After the pilot passes AND sign-off — switch DLP to enforce: .\CMPFEDRAMP-Configure.ps1 -Control DLP -Enforce -WhatIf 3) Audit evidence retention: .\CMPFEDRAMP-Configure.ps1 -Control Audit -PolicyName "Audit Retention – FedRAMP Evidence – LongTerm" -RecordTypes AzureActiveDirectory -Duration TenYears -Priority 150 -WhatIf 4) Controlled-records retention: .\CMPFEDRAMP-Configure.ps1 -Control Retention -PilotScope "FedRAMP Pilot – Controlled Data – Stage1" -WhatIf Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin. EXPECTED RESULTS -WhatIf prints each intended create/remove/change with no change. -Commit performs it and re-reads the object. PASS = object exists as intended (DLP in TEST until -Enforce). Remove objects with -Remove. Switching DLP to Enable can block users — do it only under sign-off. .NOTES Purview category — FedRAMP Compliance Program. High-impact: DLP, encryption labels, and retention are piloted in simulation/test/disabled mode first. Baseline, NIST 800-53 applicability, DLP conditions, and retention durations are security/compliance/legal determinations — supplied by you, not invented here. No certification/ATO asserted. Verify cmdlet/plan availability for your tenant. > [CmdletBinding()] param(

[Parameter(Mandatory)][ValidateSet('Label','DLP','Audit','Retention')][string]$Control,

CMPFEDRAMP-Discovery.ps1

Purpose: Reports the current Purview control posture with no changes: compliance licensing present (information protection / DLP / Audit Premium-bearing plans), existing sensitivity labels and label policies (flagging encryption), DLP policies (flagging Mode — Test/simulation vs Enable), retention labels and policies, unified audit ingestion state, and existing audit log retention policies. Maps to the NIST 800-53 families (AC/MP/SC/AU) the program addresses. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary per control domain. Any capability whose plan/behavior must be confirmed is flagged "verify your licensing/tenant", not asserted. PASS = each in-scope control is present and correctly configured (DLP in test/simulation until enforced); FAIL = a control is missing or mis-configured (drives the Implementation Guide). .NOTES Purview category — FedRAMP Compliance Program. Read-only. Feature availability is licensing-/tenant- dependent and evolving; baseline selection, NIST 800-53 applicability, and any ATO decision are deferred to your security/compliance functions (no certification/ATO asserted). Confirm cmdlet/plan names against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary per control domain. Any capability whose plan/behavior must be confirmed is flagged "verify your licensing/tenant", not asserted. PASS = each in-scope control is present and correctly configured (DLP in test/simulation until enforced); FAIL = a control is missing or mis-configured (drives the Implementation Guide). .NOTES Purview category — FedRAMP Compliance Program. Read-only. Feature availability is licensing-/tenant- dependent and evolving; baseline selection, NIST 800-53 applicability, and any ATO decision are deferred to your security/compliance functions (no certification/ATO asserted). Confirm cmdlet/plan names against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

CMPFEDRAMP-Report.ps1

Purpose: Produces the FedRAMP evidence binder with no changes: for each configured Purview control it records the implementing object, its key configuration, and a proof reference, cross-referenced to the NIST 800-53 family it supports. Exports CSV and JSON ('Evidence – FedRAMP Controls – Binder') for the security/compliance package. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Report.ps1 -OutputFolder .\evidence Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin; no secrets. Pair with CMPFEDRAMP-Discovery.ps1 / CMPFEDRAMP-Validate.ps1 outputs as before/after evidence. EXPECTED RESULTS Two files in the output folder: 'Evidence - FedRAMP Controls - Binder.csv' and '.json'. Each row = one control (info protection / DLP / audit / retention) with object name, present/absent, key settings, NIST family, and a proof pointer. Rows with no implementing object are flagged as an

evidence gap to fill before an assessment. .NOTES Purview category — FedRAMP Compliance Program. Read-only. The binder evidences that controls are CONFIGURED; it does not certify FedRAMP compliance or an ATO — baseline/applicability are security/compliance/legal determinations. Verify cmdlet/plan names for your tenant. > [CmdletBinding()] param([string]$OutputFolder = '.', [string]$LabelName = 'Protect – FedRAMP Controlled – Confidential', [string]$DlpPolicy = 'DLP – FedRAMP Controlled – Simulate', [string]$AuditPolicy = 'Audit Retention – FedRAMP Evidence – LongTerm', [string]$RetentionPolicy = 'Retention – FedRAMP Records – Publish')

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Report.ps1 -OutputFolder .\evidence Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin; no secrets. Pair with CMPFEDRAMP-Discovery.ps1 / CMPFEDRAMP-Validate.ps1 outputs as before/after evidence. EXPECTED RESULTS Two files in the output folder: 'Evidence - FedRAMP Controls - Binder.csv' and '.json'. Each row = one control (info protection / DLP / audit / retention) with object name, present/absent, key settings, NIST family, and a proof pointer. Rows with no implementing object are flagged as an evidence gap to fill before an assessment. .NOTES Purview category — FedRAMP Compliance Program. Read-only. The binder evidences that controls are CONFIGURED; it does not certify FedRAMP compliance or an ATO — baseline/applicability are security/compliance/legal determinations. Verify cmdlet/plan names for your tenant. > [CmdletBinding()] param([string]$OutputFolder = '.', [string]$LabelName = 'Protect – FedRAMP Controlled – Confidential', [string]$DlpPolicy = 'DLP – FedRAMP Controlled – Simulate', [string]$AuditPolicy = 'Audit Retention – FedRAMP Evidence – LongTerm', [string]$RetentionPolicy = 'Retention – FedRAMP Records – Publish')

CMPFEDRAMP-Scope.ps1

Purpose: Enumerates the intended in-scope population and confirms toolchain health with no changes: members of the controlled-data-owners group, the mailboxes/sites in scope, the compliance role groups it can see (for least-privilege review), and which endpoints (S&C PowerShell / Graph) are reachable. Use before configuring so the pilot scope is grounded in real objects. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Scope.ps1 -ControlledDataGroup "Controlled Data Owners" Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for group membership, Microsoft.Graph with delegated Group.Read.All / User.Read.All. Interactive modern-auth / MFA admin; no secrets. EXPECTED RESULTS A scope summary: group member count, sample in-scope mailboxes, visible role groups, and endpoint reachability. PASS = the controlled-data-owners group resolves and both endpoints are reachable; FAIL = group not found or an endpoint unreachable (resolve before configuring). .NOTES Purview category — FedRAMP Compliance Program. Read-only. In-scope controlled data and baseline are security/compliance determinations; this only enumerates what you name. Confirm cmdlet/role names against your tenant. > [CmdletBinding()] param([string]$ControlledDataGroup, # display name of the group of controlled-data owners (optional) [string]$UserPrincipalName, [switch]$SkipGraph)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Scope.ps1 -ControlledDataGroup "Controlled Data Owners" Requires ExchangeOnlineManagement (Connect-IPPSSession) and, for group membership, Microsoft.Graph with delegated Group.Read.All / User.Read.All. Interactive modern-auth / MFA admin; no secrets. EXPECTED RESULTS A scope summary: group member count, sample in-scope mailboxes, visible role groups, and endpoint reachability. PASS = the controlled-data-owners group resolves and both endpoints are reachable; FAIL = group not found or an endpoint unreachable (resolve before configuring). .NOTES Purview category — FedRAMP Compliance Program. Read-only. In-scope controlled data and baseline are security/compliance determinations; this only enumerates what you name. Confirm cmdlet/role names against your tenant. > [CmdletBinding()] param(

[string]$ControlledDataGroup, # display name of the group of controlled-data owners (optional) [string]$UserPrincipalName, [switch]$SkipGraph)

CMPFEDRAMP-Validate.ps1

Purpose: Scores the program across the three control domains with no changes: sensitivity label present (and encryption state), DLP policy present and IN TEST/simulation mode (not enforcing before sign-off), unified audit on with the evidence-retention policy present, and the controlled-records retention policy scoped. Emits a PASS/FAIL per gate mirroring the Testing Guide. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Validate.ps1 Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin; no secrets. For audit ingestion state it also uses Connect-ExchangeOnline where available. EXPECTED RESULTS A scorecard: each gate GREEN (pass) or RED (fail) with the remediation pointer. PASS overall = every in-scope gate green for the pilot scope (DLP in TEST until sign-off, then Enable on expand). Determination-level adequacy (baseline, NIST 800-53 fit, ATO) is NOT scored here — that is security/compliance/legal's. .NOTES Purview category — FedRAMP Compliance Program. Read-only. Proves the technical control works and is present; asserts no certification/ATO. Verify cmdlet/plan names for your tenant. > [CmdletBinding()] param([string]$LabelName = 'Protect – FedRAMP Controlled – Confidential', [string]$DlpPolicy = 'DLP – FedRAMP Controlled – Simulate', [string]$AuditPolicy = 'Audit Retention – FedRAMP Evidence – LongTerm', [string]$RetentionPolicy = 'Retention – FedRAMP Records – Publish', [switch]$ExpectEnforced # on expand: expect the DLP policy to be in Enable (enforce) mode)

How to run: powershell -ExecutionPolicy Bypass -File .\CMPFEDRAMP-Validate.ps1 Requires ExchangeOnlineManagement (Connect-IPPSSession). Interactive modern-auth / MFA admin; no secrets. For audit ingestion state it also uses Connect-ExchangeOnline where available. EXPECTED RESULTS A scorecard: each gate GREEN (pass) or RED (fail) with the remediation pointer. PASS overall = every in-scope gate green for the pilot scope (DLP in TEST until sign-off, then Enable on expand). Determination-level adequacy (baseline, NIST 800-53 fit, ATO) is NOT scored here — that is security/compliance/legal's. .NOTES Purview category — FedRAMP Compliance Program. Read-only. Proves the technical control works and is present; asserts no certification/ATO. Verify cmdlet/plan names for your tenant. > [CmdletBinding()] param([string]$LabelName = 'Protect – FedRAMP Controlled – Confidential', [string]$DlpPolicy = 'DLP – FedRAMP Controlled – Simulate', [string]$AuditPolicy = 'Audit Retention – FedRAMP Evidence – LongTerm', [string]$RetentionPolicy = 'Retention – FedRAMP Records – Publish', [switch]$ExpectEnforced # on expand: expect the DLP policy to be in Enable (enforce) mode)